ANAROS BEAUTY LOUNGE

BEAUTY OPERATING SYSTEM · ÉDITION 2026

SPÉCIFICATION FONCTIONNELLE & TECHNIQUE

Le planning, les clientes, l'équipe.

Logiciel de gestion pour institut de beauté : onboarding guidé, agenda par employée, clientes, catalogue de prestations et rôles.

Analyse du code déployé, dictionnaires de données, parcours utilisateurs, audit de sécurité et feuille de route.

PRODUIT
Anaros Beauty Lounge

NATURE DU DOCUMENT
Dossier produit complet

VERSION ANALYSÉE
Déploiement du 5 novembre 2026

PÉRIMÈTRE
14 écrans · 7 tables · 4 rôles

STACK
React · Express · PostgreSQL

APPLICATION
springgreen-cheetah-495703.hostingersite.com

Sommaire

Seize chapitres, de la vision produit au guide d'intégration de la vidéo. Les chapitres 05 et 07 constituent le cœur de la spécification fonctionnelle.

COMPRENDRE LE PRODUIT

01 Résumé exécutif — Stratégie
Fiche d'identité, chiffres clés, périmètre réel, ce que le produit fait et ne fait pas

02 Contexte et problème métier — Stratégie
Douleurs d'un institut, promesse, principes de conception

03 Utilisateurs et rôles — Produit
Personas, quatre rôles, matrice des droits et réalité de l'accès

04 Cartographie fonctionnelle — Produit
Les 9 modules, la navigation, le cycle de vie d'un rendez-vous

SPÉCIFICATION FONCTIONNELLE

05 Analyse module par module — Cœur
9 modules : objectif, fonctions, dictionnaire de données, règles, limites

06 Parcours utilisateurs — Cœur
Mise en service, accueil, réservation, planning terrain, fidélisation

07 Modèle de données — Cœur
7 tables, dictionnaires de champs, relations, isolation, anomalies

SPÉCIFICATION TECHNIQUE

08 Architecture technique — Technique
Couches, stack, API, build, routage, performance

09 Design system — Design
Tokens, typographie, couleurs, composants, états, responsive

10 Onboarding et mise en service — Produit
4 étapes, génération des mots de passe, données créées

11 Sécurité, données et conformité — Risque
Mots de passe, sessions, isolation, risques, recommandations

DÉCIDER ET EXPLOITER

12 Audit de maturité — Audit
Notation par module, dette technique, qualité du code

13 Feuille de route — Plan
3 phases, livrables, critères d'acceptation

14 Exploitation et déploiement — Ops
Passenger, Node.js, PostgreSQL, sauvegarde, checklist

15 Guide d'intégration vidéo — Production
Spécifications, iframe, storyboard, script voix off

16 Annexes — Référence
Routes, dépendances, captures, glossaire, traçabilité

CONVENTIONS DE LECTURE

Les montants sont exprimés dans la devise du centre, configurée à l'inscription (le jeu de démonstration utilise le dirham marocain, MAD). Les chemins commençant par / désignent des routes de l'application. Les statuts « Complet », « Fonctionnel », « Partiel » et « Phase 2 » sont définis au chapitre 12. Les captures proviennent de la version déployée le 5 novembre 2026.

01 · Résumé exécutif

VUE D'ENSEMBLE

Anaros Beauty Lounge est un logiciel de gestion pour institut de beauté : onboarding guidé, agenda par employé, clientes, catalogue de prestations, équipe et rôles. Un vrai serveur Node.js porte les règles métier et les agrégations.

1.1 Fiche d'identité du produit

Nom affiché dans l'application	Anaros Beauty Lounge
Nature	Application web complète : front React + API Express + base PostgreSQL
Métier couvert	Gestion d'institut de beauté : rendez-vous, clientes, prestations, équipe
Périmètre fonctionnel	Onboarding, tableau de bord, agenda, rendez-vous, clientes, catalogue, équipe, planning personnel, journal d'activité
Devise	Configurable à l'inscription — dirham marocain (MAD) dans le jeu de démonstration
Stack	React · Vite · TypeScript · Tailwind CSS · shadcn/ui · FullCalendar · TanStack Query · Express · Drizzle ORM · PostgreSQL
Hébergement	Hostinger — application Node.js servie par Passenger : `springgreen-cheetah-495703.hostingersite.com`
Persistance	PostgreSQL, accès via Drizzle ORM ; sessions et utilisateur courant stockés côté navigateur
Authentification	E-mail et mot de passe, vérifiés en base — sans hachage dans la version analysée
Base de données	7 tables : `profiles, services_categories, services, staff_skills, clients, appointments, tenants`
Rôles	4 niveaux : superadmin, admin, reception, staff
Volumétrie	14 écrans analysés · 7 tables · 4 rôles · 4 étapes d'onboarding · 3 vues d'agenda
État	Application convaincante et utilisable pour un institut — sécurité et isolation multi-salons à traiter avant commercialisation

1.2 Chiffres clés

14
écrans couverts par l'analyse

7
tables dans le schéma de données

4
rôles utilisateurs distincts

4
étapes d'onboarding à la création

5
statuts de rendez-vous suivis

3
vues d'agenda : jour, semaine, employé

1.3 Ce que le produit fait — et ce qu'il ne fait pas

Périmètre réellement livré

- Créer un centre en quatre étapes guidées, sans intervention technique.
- Générer automatiquement un mot de passe pour chaque employé créé.
- Tenir un agenda par employé, avec couleur et filtrage des compétences.
- Créer un rendez-vous en trois choix : cliente, employé, prestation.
- Gérer les clientes, leurs coordonnées, leurs notes et leur historique.
- Organiser un catalogue par catégories, avec prix et durées.
- Offrir à chaque employé une vue journalière de ses rendez-vous.
- Afficher un tableau de bord agrégé côté serveur.
- Journaliser les actions dans un flux chronologique.

Hors périmètre de cette version

- × Hachage des mots de passe et sessions signées.
- × Isolation réelle des données par institut (tenant).
- × Détection des chevauchements de rendez-vous.
- × Caisse, encaissement, ticket et TVA.
- × Forfaits, packs, promotions et cartes de fidélité.
- × Rappels SMS / WhatsApp et réservation en ligne.
- × Stock de produits et consommables.
- × Photos avant / après et gestion des consentements.

LECTURE HONNÊTE

Le produit raconte très bien le quotidien d'un institut et l'expérience d'interface est soignée. Deux faiblesses empêchent aujourd'hui de le vendre à plusieurs salons : les mots de passe sont comparés en clair et les requêtes ne filtrent pas par institut. Ce sont des chantiers de quelques semaines, pas des refontes.

02 · Contexte et problème métier

POURQUOI CE PRODUIT EXISTE

Un institut de beauté vit d'un planning bien rempli et de clientes qui reviennent. Le carnet papier et la messagerie ne tiennent pas la charge dès la deuxième employée.

2.1 Les douleurs du terrain

DOULEUR	MANIFESTATION CONCRÈTE	RÉPONSE APPORTÉE
Planning dispersé	Un carnet par employée, des rendez-vous notés sur WhatsApp, des trous et des doublons.	Agenda unique par employé, avec couleur et vue semaine.
Prestation mal affectée	Une esthéticienne se voit confier un soin qu'elle ne pratique pas.	Filtrage des prestations par compétence de l'employé.
Clientes oubliées	Aucun historique : impossible de savoir ce qui a été fait la dernière fois.	Fiche cliente avec notes et historique des rendez-vous.
Tarifs inconsistants	Le prix d'un soin varie selon qui répond au téléphone.	Catalogue centralisé avec prix et durée par prestation.
Mise en route technique	Un logiciel générique demande des jours de paramétrage avant le premier rendez-vous.	Onboarding en quatre étapes, centre opérationnel le jour même.

2.2 La promesse

Ouvrir la journée, voir qui vient, qui s'en occupe, pour quelle prestation et à quel prix. Puis laisser chaque employée consulter son planning et clôturer ses rendez-vous, sans repasser par la gérante.

2.3 Principes de conception

Le geste avant la donnée

Chaque écran répond à une action immédiate : prendre un rendez-vous, clôturer une prestation, ajouter une employée.

Une couleur par personne

La couleur d'un employé le suit dans le menu, l'agenda et les fiches. C'est le repère de lecture d'un planning chargé.

Chacun son périmètre

Le menu s'adapte au rôle : une employée ne voit pas la gestion de l'équipe, la réception voit l'agenda et les clientes.

03 · Utilisateurs et rôles

QUI UTILISE L'OUTIL, ET AVEC QUELS DROITS

Quatre rôles structurent l'application : superadmin, admin, réception et personnel. Le menu latéral s'adapte au rôle connecté.

3.1 Personas

PERSONA	USAGE PRINCIPAL	ÉCRANS FRÉQUENTS	BESOIN DOMINANT
Gérante / admin	Piloter l'institut	Tableau de bord, agenda, prestations, équipe	Voir le chiffre d'affaires et la charge
Réception	Accueillir et prendre les rendez-vous	Agenda, clientes, rendez-vous	Placer la bonne cliente au bon créneau
Employée / staff	Exécuter les prestations	Mon planning	Savoir qui vient et à quelle heure
Super-admin	Administrer la plateforme	Utilisateurs, paramètres	Gérer les comptes et les centres

3.2 Matrice des droits

CAPACITÉ	SUPERADMIN	ADMIN	RÉCEPTION	STAFF
Tableau de bord	Oui	Oui	Oui	Non
Agenda complet	Oui	Oui	Oui	Non
Mon planning	Oui	Oui	Oui	Oui
Créer un rendez-vous	Oui	Oui	Oui	Selon configuration
Gérer les clientes	Oui	Oui	Oui	Non
Catalogue et tarifs	Oui	Oui	Lecture	Lecture
Gérer l'équipe et les rôles	Oui	Oui	Non	Non
Journal d'activité	Oui	Oui	Non	Non
Cloisonner par institut	Non appliqué : les requêtes ne filtrent pas par tenant.			

ÉCART ENTRE LE MENU ET L'API

Le menu masque les écrans selon le rôle, ce qui donne une impression de cloisonnement. Mais les routes API ne vérifient pas le rôle ni l'institut de l'appelant : un appel direct peut lire ou modifier les données d'un autre centre. Le filtrage doit être déplacé côté serveur.

04 · Cartographie fonctionnelle

VUE D'ENSEMBLE DES MODULES

Neuf modules, dont un parcours d'inscription qui conditionne tous les autres. La navigation latérale les expose selon le rôle.

4.1 Navigation

ENTRÉE DE MENU	ROUTE	RÔLE DANS LE FLUX	TABLE PRINCIPALE
Tableau de bord	`/dashboard`	CA du jour, RDV, classements	agrégats
Agenda	`/calendar`	Planning par employé et prise de rendez-vous	`appointments`
Mon planning	`/my-schedule`	Vue terrain de l'employé	`appointments`
Clientes	`/clients`	Fiches, notes, historique	`clients`
Prestations	`/services`	Catalogue, catégories, prix, durées	`services`
Utilisateurs	`/users`	Équipe, rôles, couleurs, compétences	`profiles`
Journal d'activité	`/activity-log`	Trace chronologique des actions	`activity_logs`
Connexion	`/login`	Porte d'entrée	`profiles`
Inscription	`/register`	Onboarding en quatre étapes	toutes

4.2 Cycle de vie d'un rendez-vous

01
Cliente
Créée ou retrouvée dans Clientes, avec téléphone et notes.

02
Créneau
Clic sur l'agenda, choix de l'employé et de la prestation compatible.

03
Prestation
Statut en attente puis confirmé, l'employé exécute et clôture.

04
Analyse
Le tableau de bord agrège CA, volumes et fidélité.

UN SCHÉMA SIMPLE, PRESQUE TROP

Trois tables portent l'essentiel : `profiles` (l'équipe), `clients` (les clientes) et `appointments` (le rendez-vous). Le catalogue vit à côté. Toute la valeur produit tient dans la qualité de la jonction entre ces quatre objets.

05 · Analyse module par module

SPÉCIFICATION FONCTIONNELLE DÉTAILLÉE

Chaque module est décrit par son objectif, ses fonctions réelles, ses champs, ses règles et ses limites constatées dans la version déployée.

MODULE 01

Tableau de bord

La journée en quatre chiffres

DASHBOARD KPI FIDÉLITÉ

Objectif. Donner à la gérante une lecture immédiate de l'activité : ce qui a été encaissé aujourd'hui et ce mois-ci, combien de rendez-vous sont prévus, quelles prestations marchent et quelle cliente compte le plus.

Fonctions

- Chiffre d'affaires du jour et du mois, formatés dans la devise du centre.
- Nombre de rendez-vous du jour.
- Classement des prestations les plus demandées.
- Classement des employés les plus actifs.
- Mise en avant de la cliente « dorée », celle qui a le plus dépensé.

Règles de calcul

INDICATEUR	SOURCE	RÈGLE
CA du jour	`appointments + services`	Somme des prix des rendez-vous du jour dont le statut vaut terminé.
CA du mois	`appointments + services`	Même règle sur le mois calendaire courant.
Rendez-vous du jour	`appointments`	Nombre de rendez-vous dont la date de début tombe aujourd'hui.
Cliente dorée	`clients + appointments`	Cliente dont la somme des prestations terminées est la plus élevée.

Verdict. Module réussi : les agrégations sont faites côté serveur, donc cohérentes et rapides. Il manque une période sélectionnable et une comparaison avec le mois précédent.

MODULE 02

Agenda par employé

Le planning qui remplace le carnet papier

FULLCALENDAR RESSOURCES COMPÉTENCES

Objectif. Voir la semaine par personne, repérer les trous et poser un rendez-vous sans quitter l'agenda.

Fonctions

- Vues jour et semaine, navigation précédent / suivant / aujourd'hui.
- Une ressource par employé, avec sa couleur dédiée.
- Filtre sur un membre de l'équipe.
- Création d'un rendez-vous par clic sur un créneau.
- Prestations filtrées selon les compétences de l'employé sélectionné.

Règles

Affectation	Un rendez-vous appartient à un employé et à une prestation ; la durée affichée est celle de la prestation.

Couleur	La couleur de l'événement est celle de l'employé, ce qui rend la lecture par personne immédiate.
Compétences	La liste des prestations proposées est restreinte à celles que l'employé sait réaliser.
Chevauchement	Aucun contrôle : deux rendez-vous peuvent occuper le même employé au même moment.

RISQUE OPÉRATIONNEL

L'absence de détection de chevauchement est le défaut le plus coûteux pour un institut : deux clientes peuvent être convoquées à la même heure pour la même employée. La règle est simple à écrire (intervalle fermé sur l'employé) et doit figurer en phase 1.

MODULE 03

Prise de rendez-vous

Cliente, employé, prestation : trois choix

RENDEZ-VOUS · FILTRAGE · STATUTS

Objectif. Poser un rendez-vous en moins de trente secondes, au comptoir, avec la cliente devant soi.

Fonctions

- Recherche de la cliente par nom ou téléphone, ou création à la volée.
- Sélection de l'employé, puis de la prestation compatible.
- Date, heure de début et heure de fin préremplies à partir du créneau cliqué.
- Statuts : en attente, confirmé, terminé, annulé, non présent.
- Note libre sur le rendez-vous.

Dictionnaire de champs — `appointments`

CHAMP	TYPE	CONTENU
`client_id`	uuid	Cliente concernée
`staff_id`	uuid	Employé affecté
`service_id`	uuid	Prestation réservée
`start_time`	timestamp	Début du rendez-vous
`end_time`	timestamp	Fin calculée à partir de la durée
`status`	énumération	pending · confirmed · completed · cancelled · no_show
`notes`	texte	Précisions, préférences, incident

Verdict. Le parcours est fluide et bien pensé. Il manque l'anti-chevauchement, la possibilité de déplacer un rendez-vous par glisser-déposer et l'envoi d'une confirmation à la cliente.

MODULE 04

Clientes

Une fiche, un historique, zéro oubli

CLIENTS · HISTORIQUE · NOTES

Objectif. Retrouver une cliente, son numéro, ses préférences et la dernière prestation réalisée, pour reprendre la conversation au bon endroit.

Fonctions

- Liste et recherche par nom ou téléphone.
- Fiche avec nom, téléphone, e-mail et notes libres.
- Historique des rendez-vous de la cliente.

- Indicateurs de fréquence et de montant cumulé.
- Création rapide depuis la prise de rendez-vous.

Dictionnaire de champs — `clients`

CHAMP	TYPE	CONTENU
`first_name / last_name`	texte	Identité de la cliente
`phone`	texte	Numéro principal, utilisé pour la recherche
`email`	texte	Adresse facultative
`notes`	texte long	Allergies, préférences, produits utilisés
`tenant_id`	uuid	Institut de rattachement — présent, non filtré

Verdict. Bonne base. Manquent l'import d'un fichier existant, la fusion de doublons et un indicateur de consentement pour les rappels.

MODULE 05

Catalogue de prestations

Des prix justes, des durées réalistes

SERVICES | TARIFS | DURÉES

Objectif. Centraliser ce que l'institut propose, à quel prix et en combien de temps, pour que l'agenda et le chiffre d'affaires reposent sur la même référence.

Fonctions

- Catégories de services : onglerie, manucure, pédicure, hammam, massage, soins du visage, épilation, coiffure.
- Prestations rattachées à une catégorie, avec prix et durée en minutes.
- Création et modification sans quitter la page.
- Liste détaillée groupée par catégorie.
- Sélection des catégories puis réglage des prix pendant l'onboarding.

Dictionnaire de champs — `services`

CHAMP	TYPE	CONTENU
`category_id`	uuid	Catégorie de rattachement
`name`	texte	Nom commercial de la prestation
`price`	numérique	Prix dans la devise du centre
`duration_minutes`	entier	Durée utilisée par l'agenda
`tenant_id`	uuid	Institut de rattachement

Verdict. Module complet et lisible. Il manque les promotions, les forfaits multi-prestations et la TVA, qui viendront avec la caisse.

MODULE 06

Équipe & rôles

Chacun voit ce qui le concerne

RBAC | ÉQUIPE | COMPÉTENCES

Objectif. Constituer l'équipe, attribuer un rôle et des compétences, et donner à chaque personne un repère visuel constant dans l'agenda.

Fonctions

- Liste des membres avec rôle, profession, téléphone et couleur.
- Création d'un employé avec mot de passe généré automatiquement.
- Attribution des compétences, qui filtrent les prestations assignables.
- Menu latéral adapté au rôle connecté.
- Activation / désactivation d'un compte.

Dictionnaire de champs — `profiles`

CHAMP	TYPE	CONTENU
`email`	texte	Identifiant de connexion
`password`	texte	Mot de passe — stocké et comparé en clair dans la version analysée
`first_name / last_name`	texte	Identité affichée
`role`	énumération	superadmin · admin · reception · staff
`color_code`	texte	Couleur de l'employé dans l'agenda
`profession`	texte	Métier déclaré (esthéticienne, coiffeuse…)
`tenant_id`	uuid	Institut de rattachement

POINT BLOQUANT IDENTIFIÉ

La connexion compare le mot de passe saisi au mot de passe stocké (`eq(profiles.password, password)`). Aucun hachage, aucun sel, aucune rotation. Toute personne ayant accès à la base lit les mots de passe de l'équipe. C'est le premier chantier de la phase 1.

MODULE 07

Mon planning

La vue terrain de l'employé

STAFF JOUR ACTIONS

Objectif. Donner à chaque employée une vue simple de sa journée, avec les compteurs utiles et les actions de fin de prestation.

Fonctions

- Navigation jour précédent / suivant / aujourd'hui.
- Compteurs : total, en attente, confirmés, terminés.
- Passage d'un rendez-vous en « terminé » en un clic.
- Annulation et ajout d'une note après le passage de la cliente.
- Affichage de la cliente, de la prestation et de l'horaire.

Verdict. Excellent choix produit : c'est la vue qui fait réellement adopter l'outil par l'équipe. Il manque une vue semaine personnelle et un mode hors ligne.

MODULE 08

Journal d'activité

Savoir qui a fait quoi, et quand

JOURNAL TRAÇABILITÉ AUDIT

Objectif. Offrir une trace lisible des mouvements de la journée : création d'un rendez-vous, changement de statut, ajout d'une cliente.

Fonctions

- Flux chronologique horodaté des actions.
- Accès depuis le tableau de bord et le menu.
- Lecture réservée aux rôles autorisés.
- Base pour un futur audit plus fin.

Verdict. Utile mais encore jeune : pas de filtre par utilisateur, par type d'action ou par période, pas d'export et pas de politique de rétention. À consolider avant d'en faire un argument de conformité.

MODULE 09

Inscription & connexion

Quatre étapes pour ouvrir le salon

ONBOARDING AUTH MOT DE PASSE GÉNÉRÉ

Objectif. Permettre à une gérante de créer son centre et son équipe sans assistance, puis de se connecter simplement.

Fonctions

- Étape 1 : compte propriétaire (prénom, nom, téléphone, e-mail, mot de passe).
- Étape 2 : informations du centre (nom, description, devise, horaires).
- Étape 3 : sélection des catégories, puis prix et durées des prestations.
- Étape 4 : ajout de l'équipe, avec mot de passe généré (`prenom123`).
- Connexion par e-mail et mot de passe, session conservée dans le navigateur.

Verdict. Le parcours est la meilleure idée du produit : il transforme un paramétrage rébarbatif en conversation guidée. Le point faible est la génération de mots de passe prévisibles, à remplacer par une invitation.

06 · Parcours utilisateurs

LE FLUX RÉEL, ÉCRAN PAR ÉCRAN

Cinq parcours structurent l'usage : mise en service, accueil, réservation, exécution et fidélisation. Chacun est décrit par ses étapes et ses points de friction.

6.1 Mise en service — le premier jour

ÉTAPE	ÉCRAN	ACTION	RÉSULTAT ATTENDU
1	Inscription · étape 1	Saisir l'identité du propriétaire et choisir son mot de passe.	Compte gérant créé.
2	Inscription · étape 2	Nommer le centre, choisir la devise et les horaires.	Cadre horaire de l'agenda défini.
3	Inscription · étape 3	Cocher les catégories, puis régler prix et durées.	Catalogue opérationnel.
4	Inscription · étape 4	Ajouter les employés et leur profession.	Équipe créée, mots de passe générés.
5	Agenda	Poser un premier rendez-vous de test.	Le centre est réellement en service.

Friction : les mots de passe générés doivent être communiqués à la main. Une invitation par e-mail ou un QR code d'activation supprimerait cette étape.

6.2 Accueil et réservation — le comptoir

01
Identifier
Rechercher la cliente par téléphone ; la créer si elle vient pour la première fois.

02
Choisir
Sélectionner l'employé disponible, puis la prestation qu'il sait réaliser.

03
Poser
Cliquer sur le créneau ; les horaires et la durée se remplissent.

04
Confirmer
Le rendez-vous apparaît dans l'agenda et dans le planning de l'employé.

6.3 Exécution — la journée de l'employée

- Ouvrir **Mon planning** et lire les compteurs du jour.
- Accueillir la cliente, vérifier la prestation et l'horaire.
- À la fin du soin, passer le rendez-vous en « terminé ».
- Ajouter une note : produit utilisé, réaction, préférence.
- La note reste attachée à la cliente pour la prochaine visite.

6.4 Pilotage — la semaine de la gérante

- Consulter le **Tableau de bord** : CA du jour et du mois, rendez-vous prévus.
- Lire les classements : prestations les plus demandées, employés les plus actifs.
- Repérer la cliente « dorée » et les clientes à recontacter.
- Ajuster le catalogue si une prestation ne se vend pas.
- Vérifier le **Journal d'activité** en cas d'anomalie.

07 · Modèle de données

LE SOCLE

Sept tables PostgreSQL, gérées par Drizzle ORM. Le schéma est propre et lisible ; il lui manque l'application effective du tenant et quelques entités du métier.

7.1 Vue d'ensemble

ORGANISATION	tenants · profiles
CATALOGUE	services_categories · services · staff_skills
ACTIVITÉ	clients · appointments
RELATIONS	tenants 1—N profiles · profiles 1—N appointments · clients 1—N appointments · services 1—N appointments · profiles N—N services via staff_skills

7.2 Dictionnaire des tables

TABLE	CHAMPS PRINCIPAUX	RÔLE
tenants	id, name, description, currency, opening_time, closing_time	Institut : cadre horaire et devise.
profiles	id, tenant_id, email, password, first_name, last_name, role, color_code, profession, is_active	Membres de l'équipe et compte gérant.
services_categories	id, tenant_id, name, icon, sort_order	Grandes familles de prestations.
services	id, tenant_id, category_id, name, price, duration_minutes, is_active	Catalogue tarifé et durées.
staff_skills	id, profile_id, service_id	Compétences : quelles prestations chaque employé peut réaliser.
clients	id, tenant_id, first_name, last_name, phone, email, notes	Fiches clientes.
appointments	id, tenant_id, client_id, staff_id, service_id, start_time, end_time, status, notes	Rendez-vous et statut d'exécution.

7.3 Anomalies de modélisation

CONSTAT	CONSÉQUENCE	CORRECTION RECOMMANDÉE
Mot de passe en clair dans `profiles`	Fuite immédiate en cas d'accès à la base ou d'export	Hacher avec bcrypt ou argon2, supprimer la colonne en clair
`tenant_id` présent mais jamais utilisé en filtre	Un centre voit les données de tous les autres	Propager le tenant dans chaque requête et ajouter les contrôles serveur
Aucune contrainte d'unicité sur le créneau	Deux rendez-vous peuvent se superposer	Vérification applicative et contrainte d'exclusion PostgreSQL
Pas de table de paiement	Le CA est déduit du prix de la prestation, pas d'un encaissement	Ajouter `payments` avec montant, moyen et date
Pas de table de disponibilité	Les horaires du centre suffisent, pas les absences	Ajouter `staff_availability` et les congés

CONSTAT	CONSÉQUENCE	CORRECTION RECOMMANDÉE
Journal d'activité non modélisé dans le schéma fourni	Traçabilité incomplète	Table `activity_logs` avec acteur, action, cible, horodatage

7.4 Isolation des données

La colonne `tenant_id` existe sur les tables principales, ce qui montre que l'intention multi-instituts est présente dès la conception. Mais les fonctions d'accès lisent les tables sans clause de filtrage : le tenant est stocké, jamais appliqué. La correction est mécanique — ajouter `where eq(table.tenantId, currentTenant)` dans chaque requête — mais elle doit être systématique et testée, sinon elle donne une fausse impression de sécurité.

08 · Architecture technique

SOUS LE CAPOT

Un front React compilé par Vite, une API Express qui porte les règles métier, une base PostgreSQL accédée par Drizzle. Le tout servi par Passenger sur un hébergement mutualisé.

8.1 Couches

FRONTEND	React · Vite · TypeScript · Tailwind CSS · shadcn/ui · Wouter
COMPOSANTS MÉTIER	FullCalendar · TanStack Query · react-hook-form · Zod · Recharts
API	Express · Node.js · REST · Drizzle ORM
BASE	PostgreSQL · 7 tables · Migrations Drizzle
ACCÈS	4 rôles · Menu par rôle · Session navigateur · Thème clair / sombre

8.2 Routage

ROUTE	ÉCRAN	ACCÈS
`/login`	Connexion	Public
`/register`	Inscription en quatre étapes	Public
`/dashboard`	Tableau de bord	Admin, réception
`/calendar`	Agenda par employé	Admin, réception, staff
`/my-schedule`	Mon planning	Tous les rôles
`/clients`	Clientes	Admin, réception
`/services`	Catalogue	Admin, réception en lecture
`/users`	Équipe et rôles	Admin, superadmin
`/activity-log`	Journal d'activité	Admin, superadmin

8.3 Performance et exploitation

Build

Front compilé par Vite, API exécutée par Node dans le même hébergement. Passenger démarre l'application et sert les assets.

Données

TanStack Query met en cache les réponses de l'API et invalide après mutation. Les agrégations du dashboard sont calculées côté serveur.

Limites

Pas de file d'attente, pas de tâche planifiée, pas de cache serveur. Convient à un institut ; à revoir pour plusieurs centaines de rendez-vous par jour.

09 · Design system

DOUX À L'ŒIL, PRÉCIS À L'USAGE

L'esthétique d'institut est assumée : dégradés chauds, cartes arrondies, typographie lisible. Mais l'interface reste un outil : chaque action est à un clic, chaque statut a sa couleur.

9.1 Fondations

ÉLÉMENT	CHOIX
Primitives	shadcn/ui au-dessus de Radix UI : dialogues, sélecteurs, calendriers, badges, onglets.
Styles	Tailwind CSS avec variables de thème ; mode clair et sombre.
Iconographie	Lucide React, cohérente avec les primitives.
Typographie	Inter pour le texte, titres en graisse forte, montants alignés à droite.
Calendrier	FullCalendar avec ressources, couleurs par employé, vues jour et semaine.
Graphiques	Recharts pour les classements et répartitions du tableau de bord.

9.2 Langage visuel

RÔLE	COULEUR	USAGE
Action principale	**Rose poudré**	Boutons de création, liens actifs, accents de marque
Chiffres clés	**Or**	Montants, totaux, mise en avant de la cliente dorée
Information secondaire	**Violet**	Badges, notes, éléments de contexte
Succès	**Vert**	Rendez-vous terminé, paiement validé
Alerte	**Rouge**	Annulation, absence, suppression

9.3 Responsive et accessibilité

- Navigation latérale repliable, menu plein écran sur mobile.
- Agenda lisible sur tablette, priorité à la vue jour sur téléphone.
- Composants Radix : navigation clavier et rôles ARIA corrects.
- Contrastes à vérifier sur les badges roses en thème clair.
- Zones tactiles à agrandir sur les actions de fin de prestation.

10 · Onboarding et mise en service

LE MEILLEUR ATOUT DU PRODUIT

Quatre étapes, aucune formation, un centre opérationnel le jour même. Ce chapitre détaille ce qui est réellement créé à chaque étape.

10.1 Déroulé détaillé

ÉTAPE	ÉCRAN	DONNÉES DEMANDÉES	CE QUI EST CRÉÉ
1	Compte propriétaire	Prénom, nom, téléphone, e-mail, mot de passe	Ligne `profiles` avec rôle admin
2	Informations du centre	Nom, description, devise, heure d'ouverture, heure de fermeture	Ligne `tenants`
3	Catégories et tarifs	Catégories cochées, puis prix et durée de chaque prestation	Lignes `services_categories` et `services`
4	Équipe	Prénom, nom, téléphone, profession	Lignes `profiles` avec mot de passe généré

10.2 Génération des mots de passe

```
// Comportement constaté à la création d'un employé
password = prenom.toLowerCase() + "123"
// exemple : "amina123"
// stocké tel quel dans profiles.password, puis comparé en clair au login
```

DOUBLE PROBLÈME

Le mot de passe est **prévisible** (prénom + 123) et **stocké en clair**. Un employé peut deviner le mot de passe d'un collègue, et toute copie de la base expose l'ensemble des comptes. La correction attendue : mot de passe aléatoire à forte entropie, haché, et invitation à le changer à la première connexion.

10.3 Reprise et interruption

Le parcours ne prévoit pas de sauvegarde d'étape : si la gérante ferme le navigateur à l'étape 3, elle doit recommencer. Une table de progression ou un brouillon côté serveur éviterait cette perte, fréquente en situation réelle.

11 · Sécurité, données et conformité

CE QUI PROTÈGE — ET CE QUI NE PROTÈGE PAS

Deux failles structurantes : des mots de passe en clair et des sessions non signées. Elles doivent être traitées avant toute ouverture à un deuxième institut.

11.1 Surface d'attaque

POINT	ÉTAT	ANALYSE
Stockage des mots de passe	CRITIQUE	Comparaison directe en base, sans hachage ni sel.
Session	FAIBLE	Utilisateur courant stocké dans le navigateur ; aucun jeton signé ne protège les appels API.
Autorisation	PARTIELLE	Menu filtré côté client, routes API non contrôlées.
Isolation	ABSENTE	`tenant_id` stocké mais jamais appliqué dans les requêtes.
Injections SQL	MAÎTRISÉ	Drizzle ORM et requêtes paramétrées : pas de concaténation observée.
Secrets	À VÉRIFIER	Chaîne de connexion PostgreSQL à sortir du dépôt et à passer en variable d'environnement.
Données personnelles	À CADRER	Nom, téléphone, e-mail, notes de soin : base légale, conservation et droit d'accès à documenter.
Sauvegarde	À DÉFINIR	Aucune procédure de sauvegarde et de restauration documentée.

11.2 Recommandations prioritaires

- Hacher les mots de passe avec bcrypt ou argon2 et supprimer la colonne en clair.
- Émettre un jeton de session signé (JWT ou cookie httpOnly) et le vérifier sur chaque route.
- Appliquer le filtre `tenant_id` dans toutes les requêtes, avec un test par table.
- Contrôler le rôle côté serveur, pas seulement dans le menu.
- Ajouter la détection de chevauchement à la création et à la modification d'un rendez-vous.
- Documenter la conservation des données clientes et la procédure d'export / suppression.

12 · Audit de maturité

NOTATION PAR MODULE

Échelle : **Complet** (utilisable tel quel), **Fonctionnel** (fonctionne, finitions manquantes), **Partiel** (parcours incomplet), **Phase 2** (non implémenté).

12.1 Notation

MODULE	ÉTAT	CE QUI FONCTIONNE	CE QUI MANQUE
Onboarding	COMPLET	4 étapes, centre, catalogue, équipe	Reprise d'un parcours interrompu
Tableau de bord	COMPLET	CA jour/mois, RDV, tops, cliente dorée	Périodes personnalisées, comparaison
Agenda	COMPLET	Vues jour/semaine, ressource employé, création	Anti-chevauchement, glisser-déposer
Clientes	COMPLET	CRUD, recherche, notes, historique	Import, fusion de doublons
Prestations	COMPLET	Catégories, prix, durées, CRUD	Promotions, packs, TVA
Équipe	COMPLET	Rôles, couleurs, compétences	Congés, pointage, disponibilités
Mon planning	COMPLET	Vue jour, actions, notes	Vue semaine personnelle, hors ligne
Journal d'activité	FONCTIONNEL	Chronologie des actions	Filtres, export, rétention
Sécurité	PARTIEL	Rôles et menu filtré	Hachage, sessions signées, contrôle API
Multi-instituts	PHASE 2	Colonne tenant présente	Filtrage effectif, rôles par centre
Caisse	PHASE 2	—	Paiements, tickets, TVA

12.2 Dette technique

Dette fonctionnelle

- Mots de passe prévisibles et en clair.
- Aucune détection de chevauchement.
- Pas de caisse ni d'encaissement.
- Pas de rappels ni de réservation en ligne.
- Parcours d'onboarding non reprenable.

Dette structurelle

- Tenant stocké mais jamais filtré.
- Autorisation uniquement côté client.
- Pas de tests automatisés ni d'intégration continue.
- Chaîne de connexion à externaliser.
- Journal d'activité sans politique de rétention.

13 · Feuille de route

TROIS PHASES, PAR ORDRE DE VALEUR

Phase 1 sécurise ce qui existe, phase 2 complète le métier, phase 3 ouvre le produit aux clientes et à plusieurs salons.

13.1 Phase 1 — Sécuriser (3 à 5 semaines)

LIVRABLE	CRITÈRE D'ACCEPTATION
Hachage des mots de passe	Aucun mot de passe lisible en base ; les comptes existants sont migrés.
Sessions signées	Toute route API refuse une requête sans jeton valide ; test automatisé fourni.
Filtrage par tenant	Un utilisateur du centre A ne peut lire aucune ligne du centre B.
Contrôle de rôle serveur	Un compte staff ne peut pas appeler les routes d'administration.
Anti-chevauchement	Un rendez-vous qui chevauche un autre pour le même employé est refusé avec un message clair.

13.2 Phase 2 — Enrichir (2 à 3 mois)

- Caisse, paiements et tickets, avec TVA et moyens de paiement.
- Forfaits, packs et promotions.
- Rappels SMS / WhatsApp et confirmation de rendez-vous.
- Photos avant / après et notes de soin structurées.
- Stock de produits et consommables.
- Disponibilités, congés et absences de l'équipe.

13.3 Phase 3 — Ouvrir (3 à 6 mois)

- Réservation en ligne pour les clientes.
- Espace cliente : historique, fidélité, préférences.
- Gestion de plusieurs salons pour un même propriétaire.
- Application mobile et notifications push.
- Statistiques par employé, par salon et par période.

14 · Exploitation et déploiement

METTRE EN LIGNE ET TENIR EN LIGNE

Une application Node.js servie par Passenger : le déploiement est plus sensible qu'un site statique, car le processus et la base doivent être supervisés.

14.1 Environnements

ENVIRONNEMENT	HÉBERGEMENT	USAGE
Production	Hostinger — Node.js / Passenger	Usage réel des instituts
Recette	Instance Node.js dédiée	Validation avant mise en production
Base	PostgreSQL	Une base par environnement recommandée

14.2 Procédure de mise en production

1. Exécuter `npm run build` et vérifier l'absence d'erreur TypeScript.
2. Appliquer les migrations Drizzle dans l'ordre, avec sauvegarde préalable.
3. Vérifier les variables d'environnement : connexion PostgreSQL, secret de session, port.
4. Redémarrer l'application Passenger et contrôler les journaux au démarrage.
5. Tester la connexion, la création d'un rendez-vous et la clôture d'une prestation.
6. Vérifier que le menu correspond bien au rôle du compte de test.

14.3 Checklist de production

- ☐ Mots de passe hachés, colonne en clair supprimée.
- ☐ Sessions signées et routes API protégées.
- ☐ Filtrage par tenant testé sur les 7 tables.
- ☐ Sauvegarde PostgreSQL planifiée et restauration testée.
- ☐ Chaîne de connexion et secret de session hors du dépôt.
- ☐ Compte super-admin nominatif, mots de passe uniques.
- ☐ Mentions légales et politique de confidentialité publiées.
- ☐ Supervision : alerte si le processus Node ou la base ne répond plus.

15 · Guide d'intégration de la vidéo

LA DÉMONSTRATION EN TROIS MINUTES

La page descriptive réserve un cadre 16:9 prêt à recevoir une iframe. Ce chapitre fournit le storyboard et le script pour produire la vidéo.

15.1 Spécifications techniques

Format	MP4 H.264, 1920 × 1080, 30 images/seconde
Durée cible	2 min 45 à 3 min 15
Intégration	Iframe 16:9 dans le bloc `.video-wrap`, attributs `allowfullscreen` et `loading="lazy"`
Audio	Voix off française, musique instrumentale douce, sous-titres français
Données	Centre de démonstration uniquement, jamais de cliente réelle

15.2 Storyboard

PLAN	ÉCRAN	ACTION FILMÉE	MESSAGE
01	Inscription · étape 1	Saisie du compte propriétaire	« Votre institut commence ici. »
02	Inscription · étape 2	Nom du centre, devise, horaires	« Le cadre se met en place. »
03	Inscription · étape 3	Sélection des catégories, puis prix et durées	« Votre catalogue, vos tarifs. »
04	Inscription · étape 4	Ajout de l'équipe	« Votre équipe est prête. »
05	Tableau de bord	CA du jour, rendez-vous, classements	« La journée en quatre chiffres. »
06	Agenda	Vue semaine par employé, couleurs	« Chaque personne a sa couleur. »
07	Prise de rendez-vous	Recherche cliente, choix employé, prestation	« Trois choix, trente secondes. »
08	Mon planning	Vue employé, passage en terminé, note	« L'équipe clôture elle-même. »
09	Catalogue	Liste par catégorie, édition d'un prix	« Un tarif unique pour tous. »
10	Équipe	Rôles, couleurs, compétences	« Chacun voit ce qui le concerne. »
11	Carton final	Logo Anaros et accroche	« L'institut tourne. La gérante respire. »

15.3 Script voix off (extrait)

```
« Un institut de beauté, c'est un planning, des clientes qui reviennent,
et une équipe qui doit savoir où elle va.

Anaros réunit les trois.

Le centre se crée en quatre étapes. Le catalogue prend le prix
et la durée de chaque soin. L'équipe entre avec sa couleur.

Et le matin, il suffit d'ouvrir l'agenda : qui vient, avec qui,
pour quel soin.

Le soir, chaque employée clôture ses rendez-vous.
La gérante, elle, regarde les chiffres. »
```

16 · Annexes

RÉFÉRENCES

Routes, dépendances principales, inventaire des captures et glossaire métier.

16.1 Dépendances principales

PAQUET	USAGE
`react / react-dom`	Interface
`vite`	Build du front
`typescript`	Typage statique
`tailwindcss`	Styles utilitaires
`@radix-ui/*`	Primitives accessibles
`@fullcalendar/*`	Agenda et ressources
`@tanstack/react-query`	Cache et synchronisation des appels API
`react-hook-form / zod`	Formulaires et validation
`recharts`	Graphiques du tableau de bord
`wouter`	Routage front
`express`	API HTTP
`drizzle-orm / drizzle-kit`	Accès PostgreSQL et migrations
`pg`	Pilote PostgreSQL
`lucide-react`	Icônes

16.2 Inventaire des captures

N°	ÉCRAN
01	Connexion / inscription — étape 1
02	Création du centre — étape 2
03	Création du centre — étape 3, catégories
04	Création du centre — étape 3, prix et durées
05	Création du centre — étape 4, équipe
06	Gestion des utilisateurs et des rôles
07	Catalogue des prestations
08	Journal d'activité
09	Agenda — vue par employé
10	Agenda — création d'un rendez-vous
11	Création d'une prestation
12	Prestations — liste détaillée par catégorie
13	Agenda — vue hebdomadaire
14	Tableau de bord

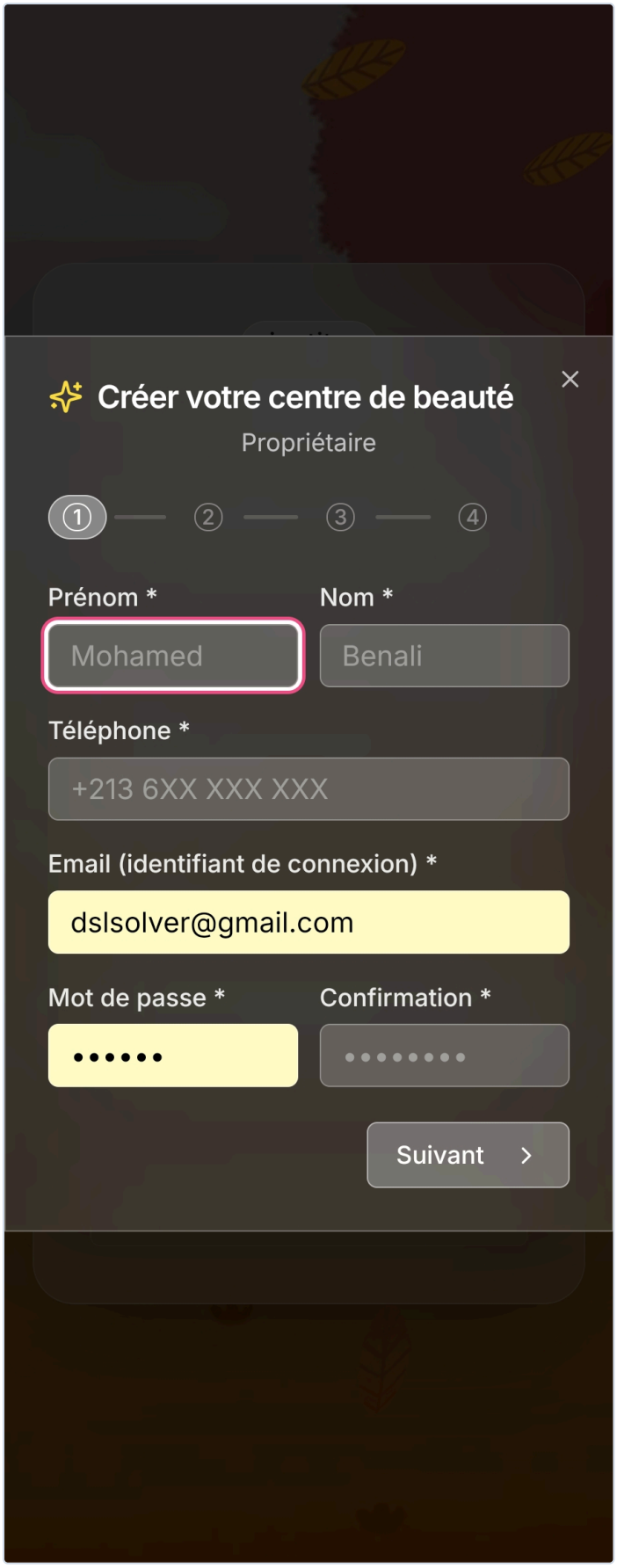
16.3 Glossaire

Institut / centre	Salon de beauté locataire du logiciel, représenté par un tenant.

Tenant	Identifiant d'isolation permettant de séparer les données de plusieurs instituts.
Prestation	Soin proposé au catalogue, avec un prix et une durée.
Catégorie	Famille de prestations : onglerie, hammam, massage, soins du visage…
Compétence	Association entre un employé et une prestation qu'il sait réaliser.
Rendez-vous	Réservation d'une prestation par une cliente auprès d'un employé, à un horaire donné.
Mon planning	Vue journalière personnelle de l'employé, avec ses actions de clôture.
Cliente dorée	Cliente ayant généré le plus de chiffre d'affaires sur la période analysée.
RBAC	Contrôle d'accès basé sur les rôles : superadmin, admin, réception, personnel.

16.4 Captures de l'application

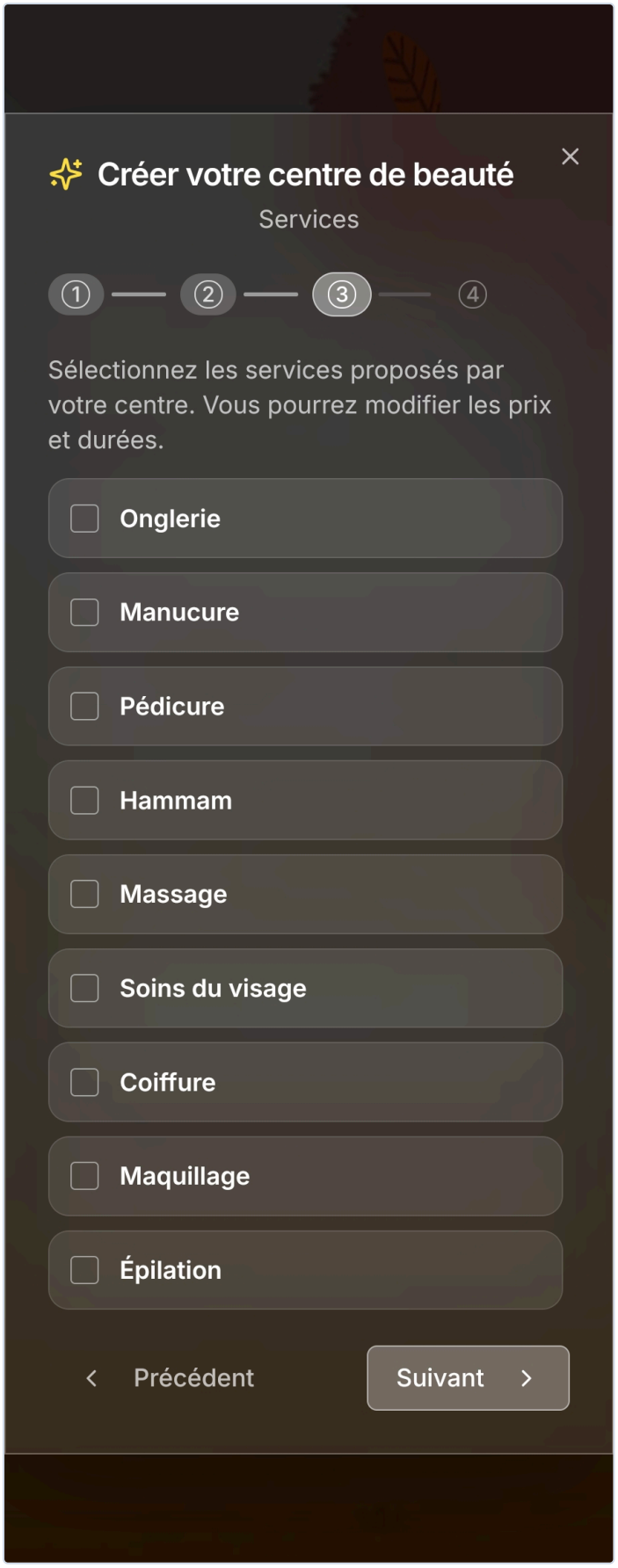
Les quatorze captures ci-dessous proviennent de la version déployée. Elles illustrent le parcours d'inscription puis l'usage quotidien de l'institut.



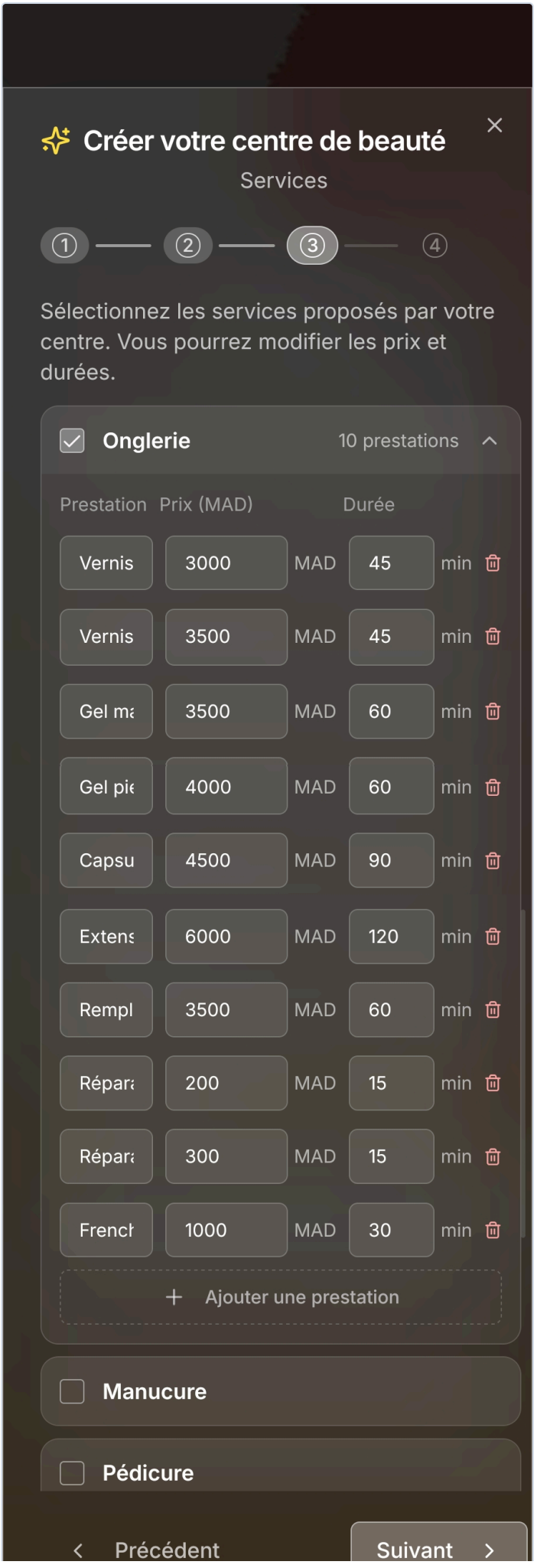
Inscription · étape 1 — compte propriétaire



Inscription · étape 2 — informations du centre



Inscription · étape 3 — catégories de services

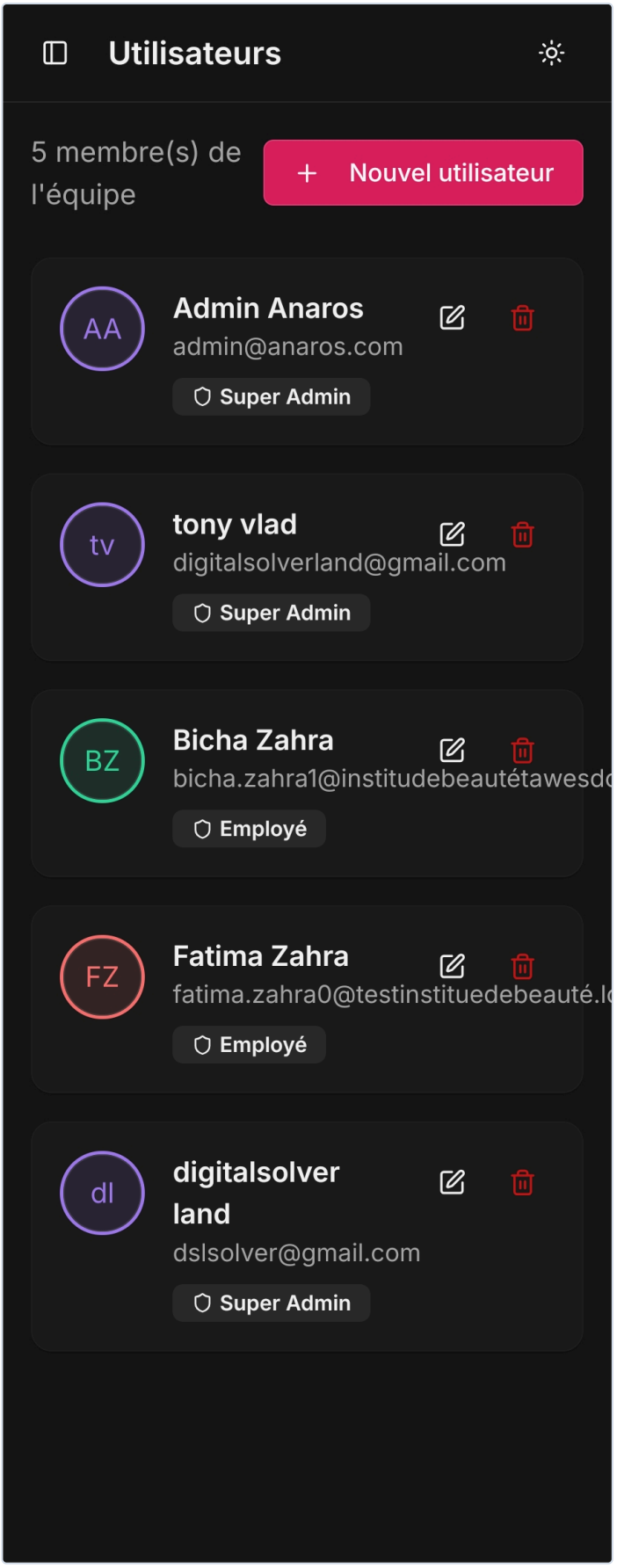




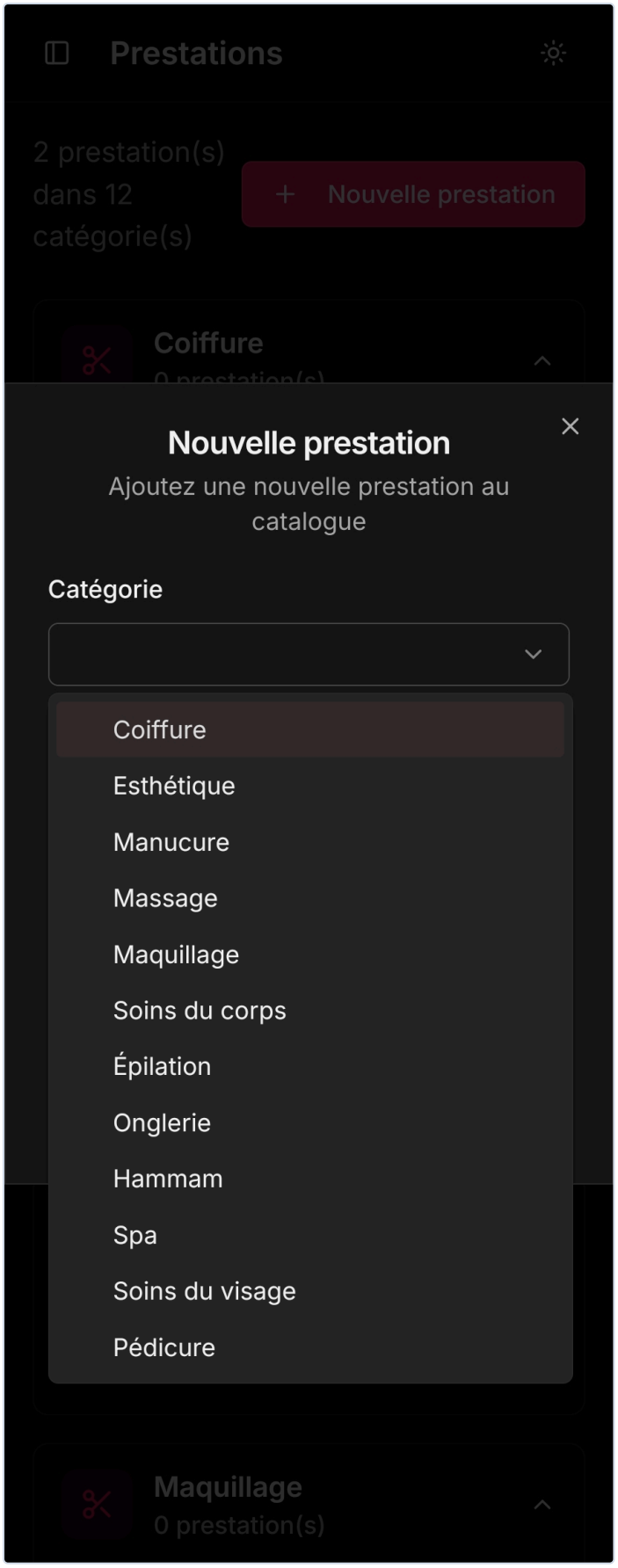
Inscription · étape 3 — prix et durées



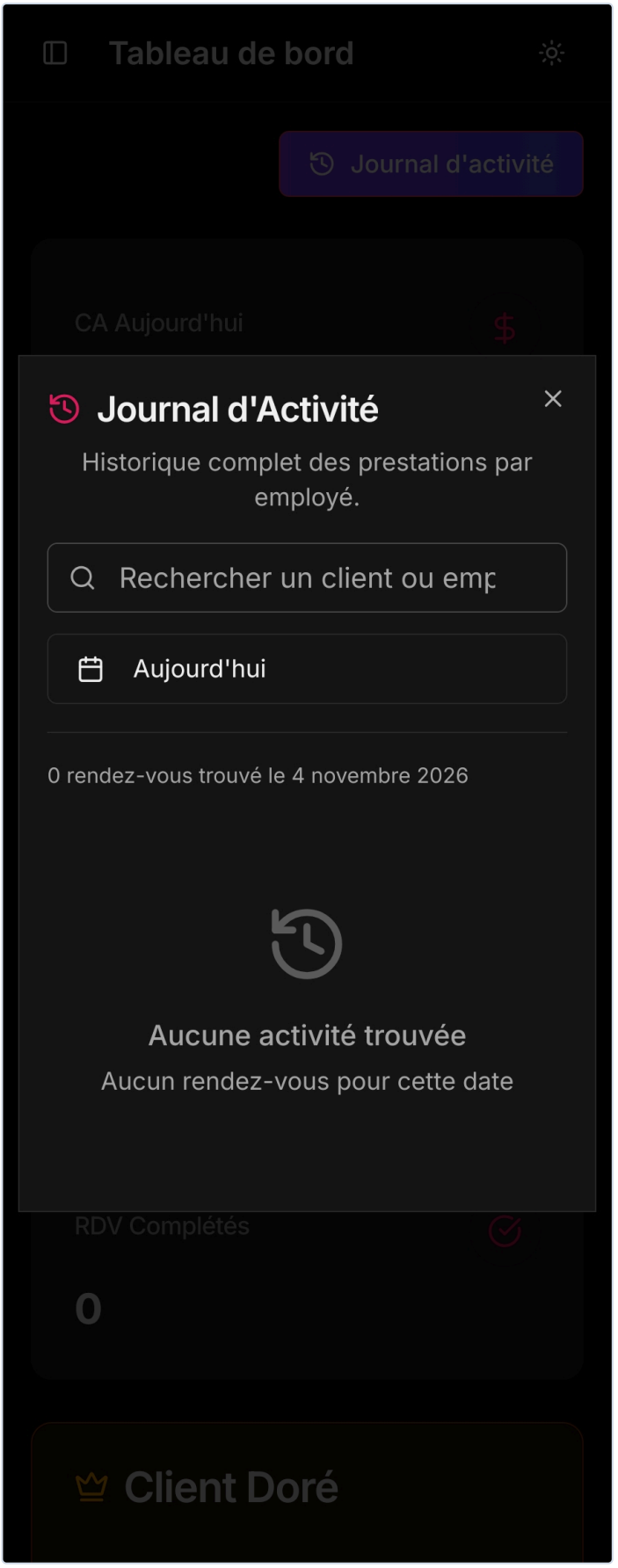
Inscription · étape 4 — ajout de l'équipe



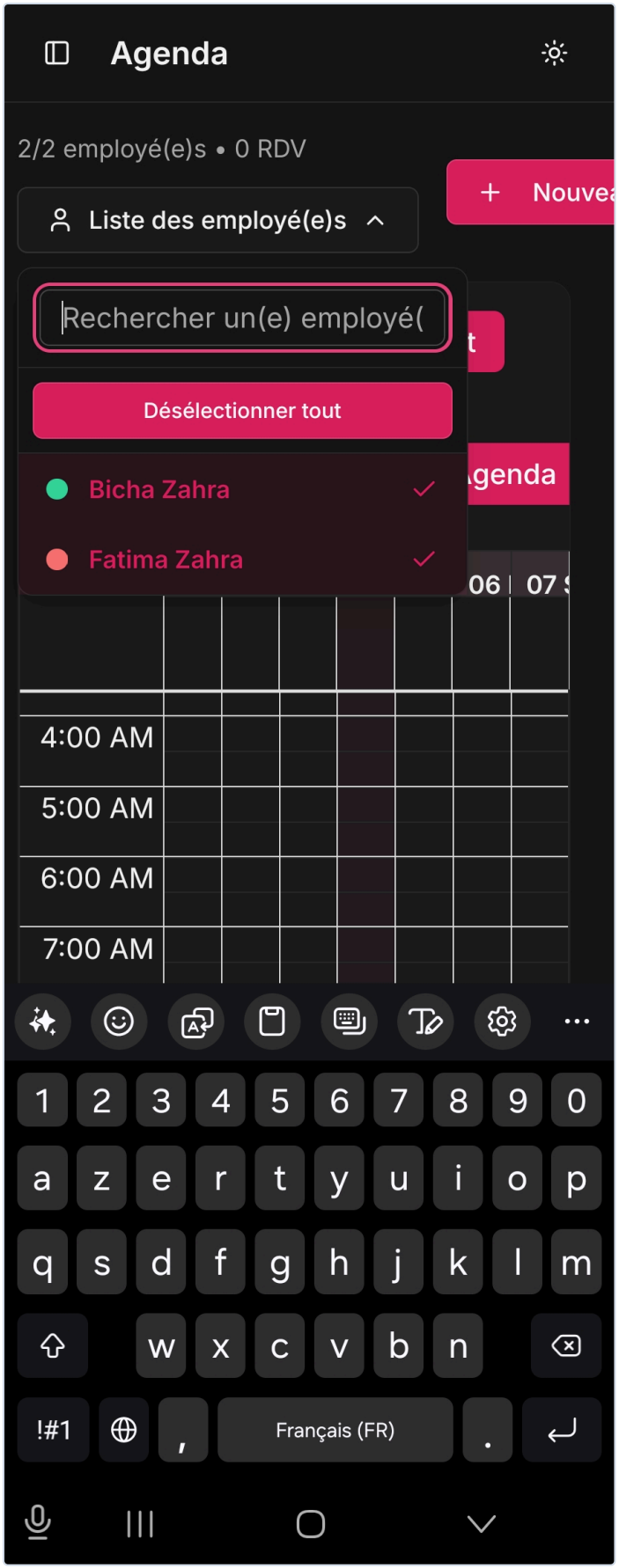
Équipe — rôles et couleurs



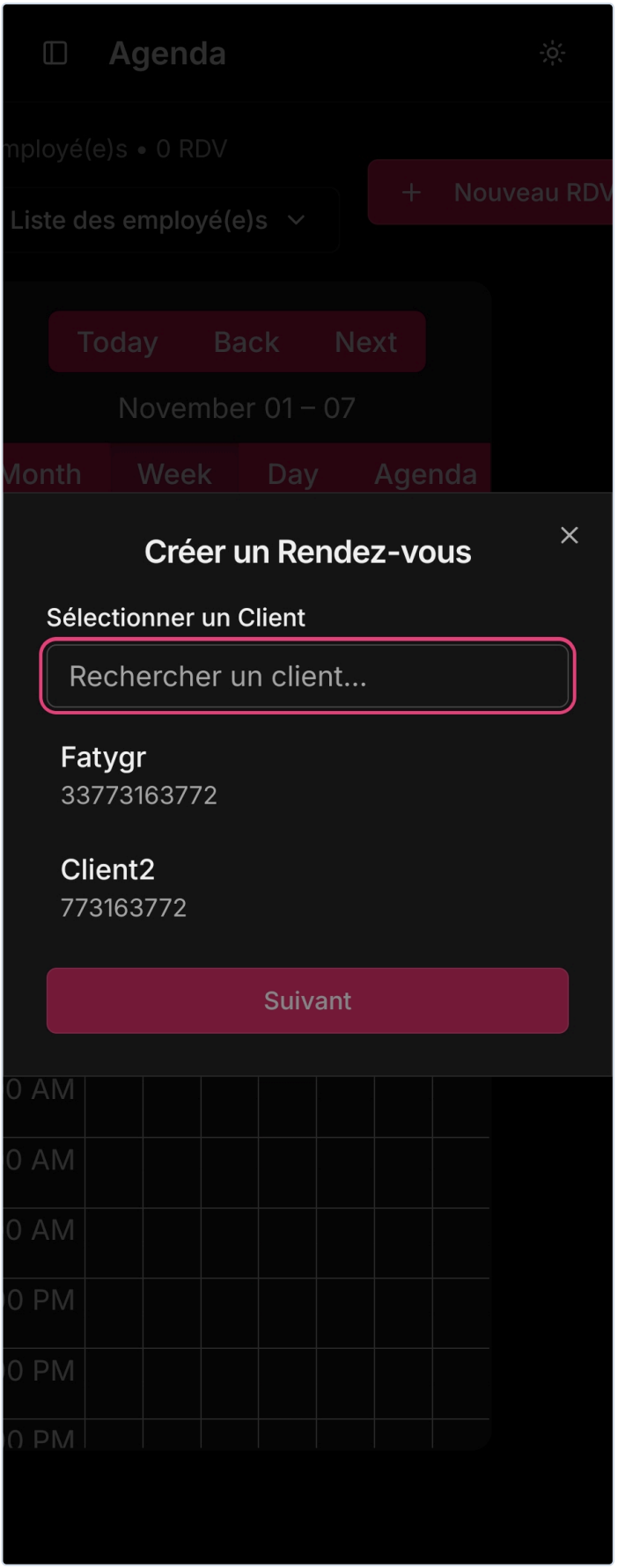
Catalogue — prestations par catégorie



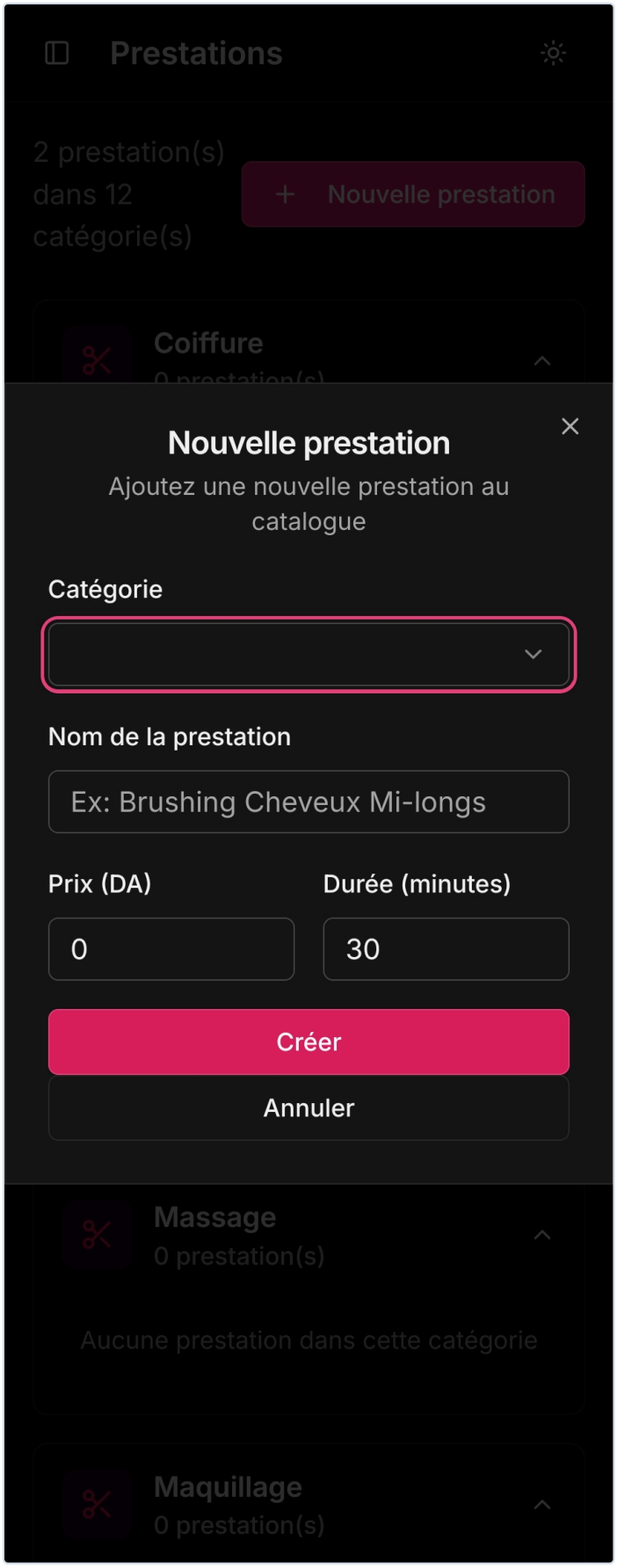
Journal d'activité — chronologie



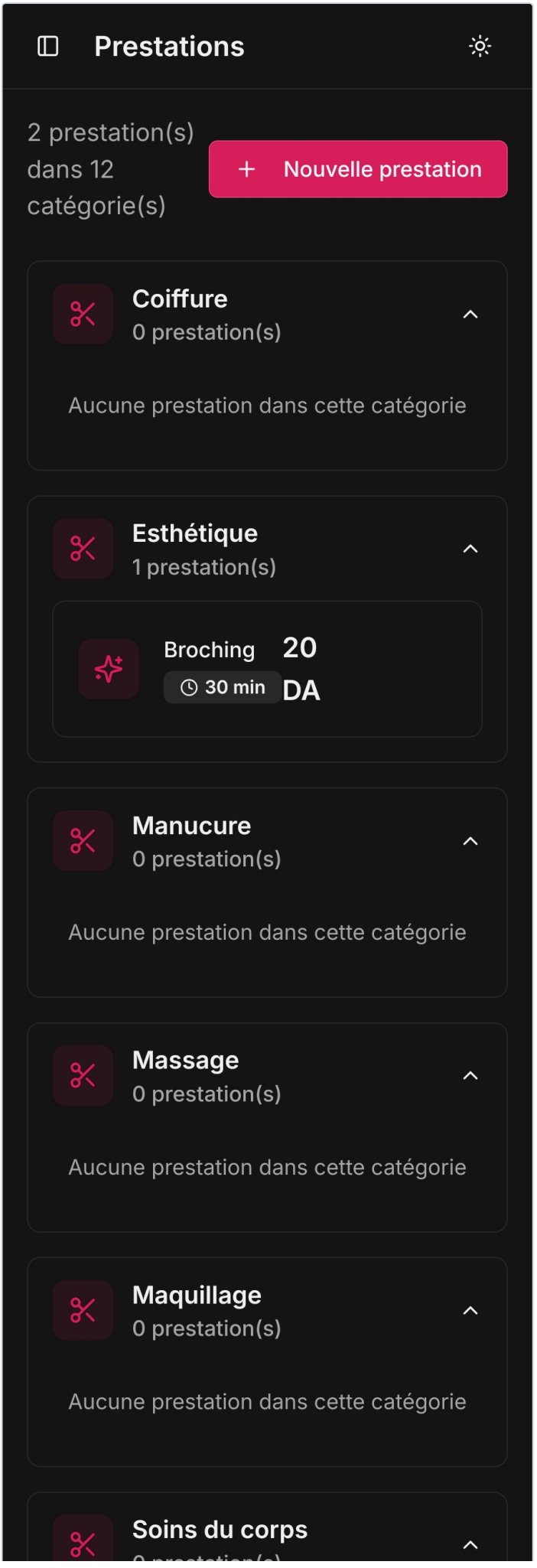
Agenda — vue par employé



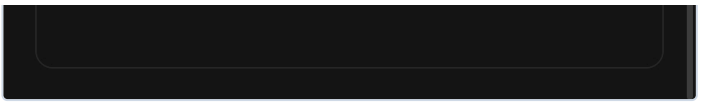
Agenda — création d'un rendez-vous



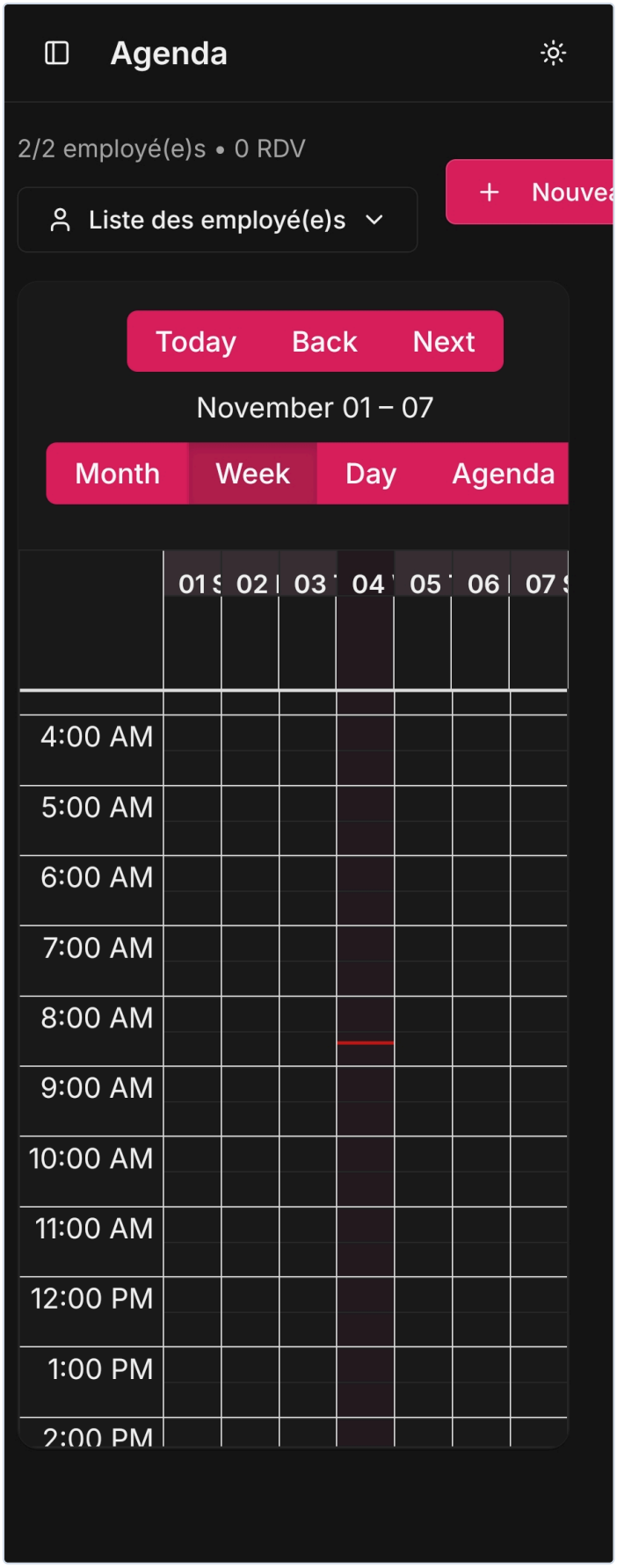
Catalogue — création d'une prestation



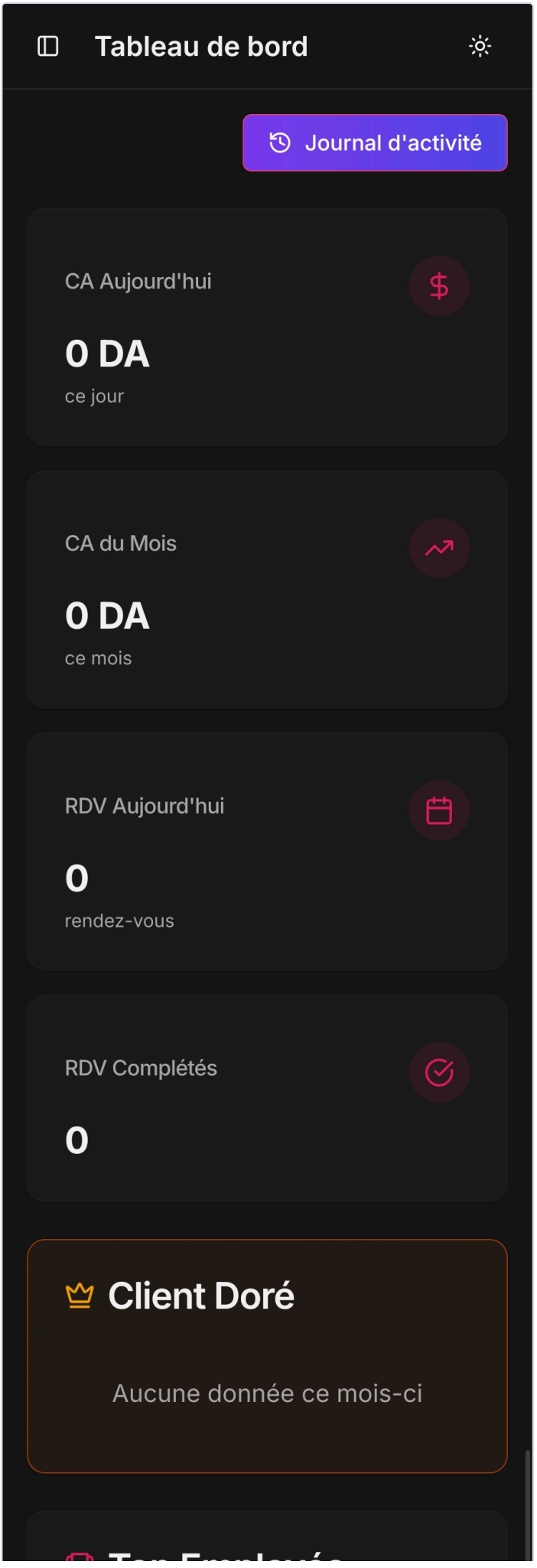

0 prestation(s)
Aucune prestation dans cette catégorie
Épilation
0 prestation(s)
Aucune prestation dans cette catégorie
Onglerie
0 prestation(s)
Aucune prestation dans cette catégorie
Hammam
0 prestation(s)
Aucune prestation dans cette catégorie
Spa
1 prestation(s)
spaspo
30 min
210
DA
Soins du visage
0 prestation(s)
Aucune prestation dans cette catégorie
Pédicure
0 prestation(s)
Aucune prestation dans cette catégorie



Catalogue — liste détaillée par catégorie



Agenda — vue hebdomadaire



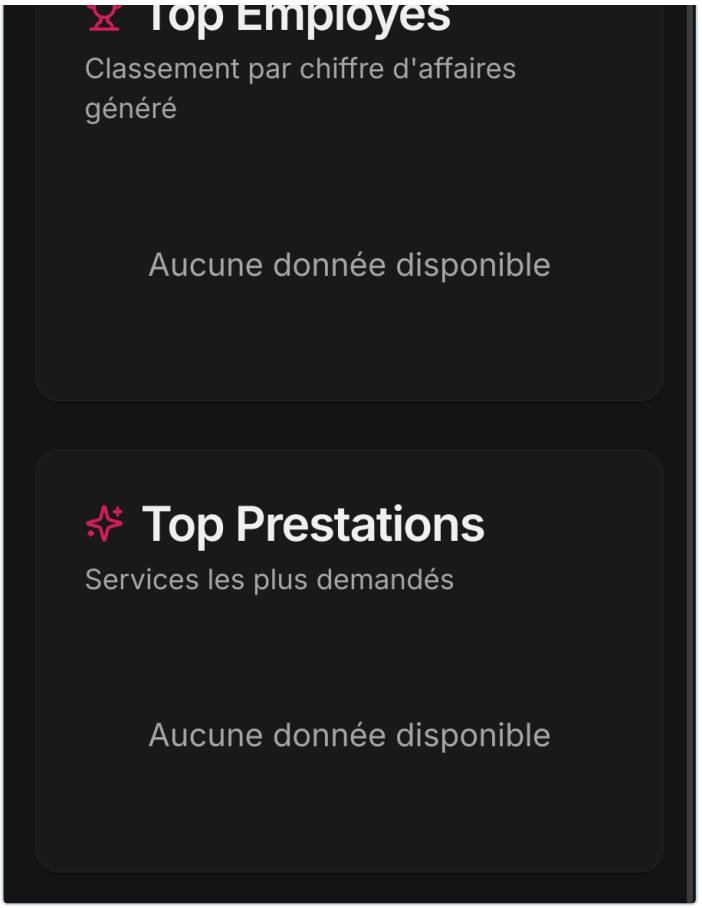


Tableau de bord — CA, RDV, classements

TRAÇABILITÉ

Document établi le 5 novembre 2026 à partir du code source de l'application, des routes, du schéma Drizzle et des écrans déployés sur `springgreen-cheetah-495703.hostingersite.com`. Les constats de sécurité cités (comparaison de mot de passe en clair, absence de filtrage tenant, absence de détection de chevauchement) proviennent de la lecture du code serveur.